

Selection-robust clinical-harm bounds from a real ransomware-incident corpus, and their effect on a control-adequacy certificate

2026-09-20 (working note, version 0.1.0)

Abstract

Estimates of which hospital services ransomware harms most are usually read straight off incident reports, ignoring that reports are a selective sample. We take the CIPHER corpus (316 coded patient-harm records from real hospital-ransomware incidents) and, instead of treating its shares as unbiased, compute *partial-identification* bounds under bounded underreporting – an honest interval per clinical service rather than a point rate. Among the 128 high-severity records (impact score ≥ 7), pharmacy (21.1%) and laboratory (18.8%) carry more severe harm than the electronic health record (14.8%), and 31.2% of severe harm falls in domains the model does not represent at all. Feeding these real-data-derived degradation intervals into the clinical-impact certificate changes a conclusion: the hospital-core control bundle, which is *not* certified at the 5% level under assumed inputs (5.3%), *is* certified under the real-data intervals (3.9%). The contribution is the first inferential use of this corpus and the selection-aware grounding, not a new theorem.

1 Data and why bounds

CIPHER (Straw, Tully, Dameff; CC-BY) codes patient-harm records from real hospital-ransomware incident reports, each with a clinical-impact score, harm-onset time point, and technical domain. It is a **convenience sample of reported harms**: unreported harms are missing not at random, so a naive share is biased. We therefore bound. Mapping technical domains to the four modelled clinical services uses the repository’s existing coverage map (Health Records $\rightarrow$ EHR, Laboratory Systems $\rightarrow$ laboratory, ePrescribing $\rightarrow$ pharmacy, Imaging $\rightarrow$ imaging); every other domain is kept as an explicit unmodelled residual, never dropped.

2 Method

Among high-severity records, let n_s be service s ’s count and T the total (including the residual). Under the assumption that any domain’s true count is at most $(1 + \gamma)$ times its observed count, service s ’s true share lies in

$$\left[\frac{n_s}{n_s + (1 + \gamma)(T - n_s)}, \frac{n_s(1 + \gamma)}{n_s(1 + \gamma) + (T - n_s)} \right].$$

At $\gamma = 0$ this is the observed share; it widens monotonically with γ and stays in $[0, 1]$. This is Manski-style partial identification; γ is a transparent worst-case dial, not a fitted selection model.

Table 1: High-severity harm by clinical service: observed share and the $\gamma = 1$ partial-identification interval (percent of all high-severity records).

Service	Records	Observed share (%)	$\gamma=1$ interval (%)
ehr	19	14.8	8.0–25.9
laboratory	24	18.8	10.3–31.6
pharmacy	27	21.1	11.8–34.8
imaging	18	14.1	7.6–24.7

Table 2: Clinical-impact certificate under assumed vs. CIPHER-derived degradation intervals.

Degradation input	Undefended union (%)	Hospital-core union (%)	Core guar. $\leq 5\%$
Assumed	44.9	5.3	no
CIPHER ($\gamma=1$)	33.0	3.9	yes

3 Results

Observed high-severity shares invert the usual intuition: pharmacy and laboratory lead, not the EHR (Table 1), and 31.2% of severe harm is in domains outside the model (infrastructure, operating rooms, communications). The harm-onset profile puts 30.7% of records at Week 2 or later, corroborating that a short recovery horizon understates real harm.

Using the $\gamma = 1$ intervals as the certificate’s per-service degradation changes a decision (Table 2): undefended union clinical outage moves from 44.9% (assumed) to 33.0% (real-data, lower because roughly a third of severe harm is unmodelled), and the hospital-core bundle crosses from *not* certified at 5% (5.3%, guaranteed: no) to certified (3.9%, guaranteed: yes). The point is not the direction of the shift but that the certificate’s answer is sensitive to this input, and grounding it in real data — with honest bounds — is preferable to an assumption.

4 Limitations

CIPHER is reported harm, not incidence; the shares are relative severity-attribution among reported harms, not probabilities from a random sample. The single- γ underreporting envelope is a worst-case device, not a fitted model; counts are small, so intervals are wide – the honest consequence. The domain-to-service mapping is the repository’s coverage mapping and leaves a large unmodelled residual. This is a real-data grounding of one certificate input via partial identification, not a new statistical method and not a validated estimate of any hospital’s risk.

Reproducibility. CIPHER v1.0.1 is used unmodified (CC-BY), hashed in a provenance manifest with every input; all numbers here are generated from the committed tables.